

Chinmay Dhok

Master Self-Assessment & Accomplishments Record

Role: Senior Information Security Analyst | **Organization:** OnlineSales.ai / Osmos.ai

Review Period: November 2025 – August 2026 • Prepared for Annual Performance Review & Executive Impact Record

Executive Summary

Over a 9-month review period (Nov 2025 – Aug 2026), the Information Security function delivered over **100 completed initiatives** across cloud governance, code supply chain protection, regulatory compliance, enterprise deal enablement, and IT SaaS cost optimization.

Key milestones include achieving **ISO 27001:2022 re-certification with zero major non-conformities**, renewing **SOC 2 Type II** compliance with clean reports, auditing and securing **524 GitHub code repositories**, resolving critical endpoint hardware degradation across macOS devices, completing major enterprise TPRM clearances (dunnhumby, PayPal, Pine Labs, BharatPe), and automating security operations through self-built AI tools.

Core Metrics Dashboard

Strategic Focus Area	Primary Metric / Target	Organizational Impact
Code Supply Chain Security	524 Repositories Audited & Remediated	Zero active IOCs/malware; 42 repos patched for high-severity Axios vulnerabilities; Litellm package pinning.
Certifications & Compliance	0 Major Non-Conformities	ISO 27001:2022 re-certified; SOC 2 Type II report issued; 100% DPDPA & privacy compliance.
Endpoint & Fleet Governance	90%+ Fleet Stability Achieved	Eliminated 20–30% Mac CPU/battery drain caused by Intune loops; trialed JumpCloud & Hexnode.

Strategic Focus Area	Primary Metric / Target	Organizational Impact
Identity & SaaS Optimization	267 GWS Accounts & 56 Gemini Seats	Right-sized tiers; purged stale/suspended accounts; zero unmonitored SaaS overhead.
Enterprise TPM & Sales	100% On-Time Partner Approvals	Unlocked commercial deals with dunnhumby, PayPal, Pine Labs, BharatPe, PepsiCo, Bed Bath & Beyond.
Access Governance & PAM	~700 Repos & 194 Extension Users	Org-wide GitHub branch protection; GCP Terraform PAM modules; Chrome extension security review.

Executive Praise & Stakeholder Recognition

"Great job @Chinmay Dhok and @Khandu Gore to run the compliance process across the org."
 — Shantanu Harkut, VP of Engineering / CTO, Osmos.ai (on achieving SOC 2 Type II compliance)

"A huge shout-out to Chinmay for owning the InfoSec questionnaire end-to-end in the recent RFPs/RFIs! Chinmay's turnaround time was lightning fast—every response came back quicker than we could have hoped, which kept the entire conversation moving without a single blocker. You've truly been the backbone of this InfoSec side of the world."
 — Siddharth Akujkar, Sales / RFP Team (Endorsed with 28 team reactions)

"Absolute Superstar! No reminders, no follow-ups - just flawless execution at lightning speed. Blink, and it's already done."
 — Barkha Kewalramani, RFP/RFI Delivery Lead

"Great submission... clear, complete, and exceptionally structured."
 — Brent Payne, Global Organisational Resilience & Internal Investigations Manager, dunnhumby (on TPM submission)

1. Endpoint Security, Fleet Optimization & MDM Modernization

(Captured via internal engineering threads & leadership directives)

1.1 Internal Infrastructure & Endpoint Security Audit

Following a directive from Shantanu Harkut (VP of Engineering) in November 2025 to perform an enterprise-wide infrastructure review, conducted an in-depth audit of endpoint devices, management agents, and identity friction.

- **The "Intune Tax" Discovery:** Identified that severe user complaints regarding 20–30% battery drain, fan noise, and overheating on macOS devices were directly caused by infinite retry loops within the Microsoft Intune Management Extension (IME) agent.
- **Linux Infrastructure Gap:** Uncovered that Linux development machines were entirely unmanaged, creating compliance gaps in SSH key rotation, OS patching, and central visibility.
- **Identity Fragmentation:** Identified a lack of true Single Sign-On (SSO) synchronization between local device logins and Google Workspace credentials.

1.2 Phase 1: Fleet Stabilization & Remediation Execution

- Guided Pramod Nikam (Senior System & Network Admin) to strip out conflicting legacy configurations causing Intune infinite loops.
- Re-architected OS update policy windows to align with local business hours (IST) to prevent background CPU spikes.
- Successfully completed user acceptance testing on internal test devices by January 7, 2026. Following data validation on January 15, deployed stabilized policies company-wide on January 30, 2026, restoring fleet performance.

1.3 Phase 2: Strategic MDM & Identity Modernization

- **JumpCloud Assessment:** Collaborated with Rockladder to schedule and run a technical demonstration on January 7, 2026, targeting unified identity and device management across macOS, Windows, and Linux fleets.
- **Hexnode UEM Evaluation:** Initiated a trial of Hexnode UEM to evaluate Apple's native lightweight MDM framework, eliminating heavy agent overhead while identifying potential cost savings (~\$5/device vs. ~\$16+ competitor average).

2. Security Governance, Cloud Architecture & Threat Defense

2.1 Code Supply Chain Protection & Dependency Hardening

- **524 Repository Audit:** Executed an automated, org-wide GitHub audit across 524 code repositories, confirming zero active Indicators of Compromise (IOCs) or malware.
- **Axios Patching:** Identified and remediated critical high-severity vulnerabilities in `axios`, upgrading 42 affected repositories to version `>= 1.8.2`.
- **Package Safe-Pinning:** Implemented strict semantic version pinning for critical core packages (including `lighthouse`), neutralizing upstream supply-chain injection vectors.
- **CI/CD Security Pipelines:** Integrated CodeAnt AI and automated CodeReview security dashboards directly into GitHub Actions CI/CD workflows to block non-compliant PRs before merging.

2.2 GCP Access Governance, PAM & Zero-Trust Architecture

- **Privileged Access Management (PAM):** Engineered and deployed GCP PAM entitlements as Terraform code, establishing scoped read, contribute, and admin tiers with a production guide.
- **Zero-Trust Network Perimeter:** Transitioned legacy VPN entry points to encrypted, audit-logged Tailscale remote access.
- **Secure GCS Provisioning:** Designed production-grade GCS buckets for developer CMS workloads enforcing Uniform Bucket-Level Access (UBLA) and Public Access Prevention (PAP).
- **Bare-Metal Integration:** Provisioned least-privilege GCP service account IAM bindings for cross-environment feed-sync workloads with Hetzner bare-metal servers.
- **SCC Findings Triage:** Triage and resolved 42 critical GCP Security Command Center findings, addressing HAProxy public exposure, over-privileged SAs, and unrotated keys.

2.3 Incident Response, VAPT & Monitoring Enhancements

- **Offensive VAPT:** Executed internal security testing across web applications, iOS/Android SDKs, and in-store Ad Servers, resolving CORS misconfigurations, rate limiting gaps, and business logic flaws.
- **Threat Neutralization:** Executed org-wide Shai-Hulud scans for CVE-2026-45321 (TanStack) and remediated a cryptomining compromise on a test-framework project.
- **Real-Time Observability:** Built automated Cloud SQL memory/CPU spike alerts and continuous health monitoring for the internal Hades backend architecture.

3. Compliance Frameworks, Certifications & Policy Audits

Standard	Auditor	Result	Strategic Focus & Artifacts
ISO 27001:2022	INTERCERT	Certified (0 Major NCs)	Stage-2 Surveillance Audit completed June 3–4, 2026.
SOC 2 Type II	Accorp Partners	Report Issued (Clean)	Full evaluation period verified with clean opinion.
GDPR / CCPA	Scrut Automation	Satisfactory Rating	Audited transfers, cookie consent, DSAR SLAs, retention.
DPDPA (India)	Scrut / Internal	Fully Compliant	Published website disclosures and opt-in forms.
Policy Governance	Internal / Scrut	54 Policies Modernized	Utilized LLM + manual review to purge legacy clauses.

4. Enterprise TPRM, RFPs & Commercial Deal Enablement

4.1 dunnhumby Enterprise TPRM Clearance

Collaborated directly with Brent Payne and Anzar Berqi to compile and deliver a detailed TPRM package:

- **High-Availability Architecture:** Evidenced a **99.9% Uptime SLA** backed by multi-region, geo-redundant GKE clusters across North America and the EU. Documented failover mechanics utilizing GCP Load Balancing, Cloud Armor WAF, and DNS routing (Target RTO $\leq$ 4 hours, RPO $\leq$ 15 minutes).
- **Data Residency & Controls:** Detailed primary hosting in us-central1 with Belgian/Frankfurt options. Demonstrated SHA256 irreversible hashing for PII, 13-month campaign data retention, and 7-year financial record retention.
- **Trust Verification:** Delivered audited SOC 2, ISO, penetration test, and security artifacts via the Osmos Security Trust Vault.

4.2 Enterprise Partner Onboarding & Vendor Management

- **PayPal BGV Compliance:** Evaluated background verification vendors to satisfy enterprise requirements, onboarding Quinfy as a cost-effective, compliant solution.
- **Pine Labs Clearance:** Resolved complex DPA technical queries, updated network topologies, and secured risk committee sign-off.
- **BharatPe Risk Assessment:** Authored response matrices and evidence packets covering encryption, IR, network isolation, and DR protocols.
- **RFP Acceleration:** Authored security attestations that unblocked enterprise deals for PepsiCo, Bed Bath & Beyond, PayPal, and MTN.

4.3 Security RFP Automation & Tooling

- **Osmos Security RFP AI Tools:** Engineered an LLM-powered reusable Gemini/Claude knowledge base that auto-answers security questionnaires, vendor TPRM forms, and DPIA/PIA documents (V2 in progress).

5. Enterprise IT Operations & SaaS Cost Optimization

5.1 Google Workspace (GWS) Migration & Sanitization

Led a domain-wide migration and license restructuring across 267 Google Workspace user accounts:

- **Enterprise Standard (200 Seats):** Provisioned power users with Vault, advanced DLP, and Context-Aware Access.
- **Business Starter (67 Seats):** Right-sized operational seats to lower cost tiers.
- **Account Sanitization:** Permanently purged suspended, offboarded, and unassigned licenses, eliminating recurring subscription waste.

5.2 Enterprise Gemini AI Seat Optimization

Audited usage metrics across 56 Google Gemini AI licenses (37 Business, 19 Enterprise). Reallocated dormant seats directly to active engineering and product teams, maximizing tool ROI and eliminating idle licensing costs.

SaaS Resource	Pre-Optimization State	Post-Optimization Outcome
GWS User Tiers	Unstructured Tiers	200 Enterprise / 67 Starter
Suspended GWS Seats	Unassigned Paid Seats	Zero Stale Active Licenses

SaaS Resource	Pre-Optimization State	Post-Optimization Outcome
Gemini AI Subscriptions	56 Unmonitored Seats	Reallocated (37 Biz / 19 Ent)

6. Email, Brand Trust & Network Security

- **Gmail BIMI & VMC Rollout:** Secured DigiCert VMC approval, aligned DMARC policies (p=reject), and deployed SVG/PEM assets to S3, establishing verified blue checkmark domain authentication for osmos.ai.
- **Anti-Phishing Defense:** Neutralized an active invoice-fraud phishing campaign targeting Finance, identifying typosquat domains and updating Workspace blocked-sender rules.
- **Ad Server & Office Network Hardening:** Hardened office and in-store networks with gateway traffic shaping (30/2 Mbps), IDS/IPS controls, DHCP IP-MAC binding for 190 laptops, and UniFi/Ruckus AP alert policies.
- **Security Automation:** Developed a Google Apps Script mail-merge system, Chrome extension security auditor (~194 users reviewed), and Zoho ticketing automation for daily network health checks.

7. Strategic Focus & Roadmap (Upcoming Initiatives)

- **VAPT Expansion:** Conducting security testing on dealroom-ui (Next.js / Supabase) utilizing Claude Code.
- **AI Tooling V2:** Deploying Osmos Security RFP Gemini App V2 and automated phishing simulation programs via Google Apps Script.
- **GCP Threat Detection Buildout:** Expanding logging and scanning across Cloud Run, Container Registry, Cloud DNS, Artifact Guard, and Notebook Security Scanner.
- **Advanced Access Controls:** Implementing Context-Aware Access, Google Workspace DLP policies, and Mobile Device Management (MDM) for iOS/Android.
- **Cyber Insurance:** Finalizing feature enablement and eligibility assessment for ECOZ coverage.